

Information Security Guidelines

Northwind Labs · Security Team · Classification: Internal

These guidelines expand on the Security Policy with practical detail for every employee. Where a number here differs from the Security Policy, the Security Policy governs · these guidelines exist to explain how to comply, not to set the rule.

1. Device Security

All company laptops and workstations must run full-disk encryption, which is enforced by device management at setup. Screens must lock automatically after a short idle period, and operating systems and browsers must stay on supported, patched versions. Do not store the only copy of sensitive data on a local disk.

- Full-disk encryption is mandatory and verified centrally.
- Automatic screen lock and a strong device passcode are required.
- Install security updates within seven days of release.

2. Authentication and Access

Sign in to company systems through single sign-on. Multi-factor authentication is required for SSO and for any access to sensitive or production systems. Use the company password manager for service credentials; never reuse a personal password for work. Access follows least privilege: you receive only the access your role needs.

Production access

Access to production systems is privileged. It requires multi-factor authentication and explicit approval from the security team before it is granted, and it is reviewed periodically. Standing production access is avoided in favor of time-bound, just-in-time grants.

3. Network and Remote Access

When working away from the office, connect to internal systems through the company-approved VPN. Treat public and untrusted Wi-Fi as hostile: the VPN must be on before you reach any internal service. Keep your home router firmware current and its admin password changed from the default. The VPN requirement here is the same one referenced by the Remote Work Policy.

4. Incident Response

If you see anything suspicious · a phishing attempt, a lost device, unexpected access, or a possible data exposure · report it immediately. Reporting early is always the right call; the security team would far rather triage a false alarm than learn of a real incident late.

- Report through the security hotline or the security ticket queue.
- Do not attempt to investigate or remediate on your own; preserve evidence.
- The on-call security engineer acknowledges and begins triage as soon as a report arrives.

5. Data Handling

Classify data as Public, Internal, Confidential, or Restricted and handle it according to its class. Share Confidential and Restricted data only with those who need it, and only over approved, encrypted channels. Delete data you no longer need in line with the retention schedule.

Class	Examples	Sharing	At rest
Public	Marketing, docs site	Anyone	No restriction
Internal	Org charts, plans	All employees	Encrypted
Confidential	Customer data, code	Need-to-know	Encrypted + access log
Restricted	Secrets, keys, PII	Named approvers	Vaulted + MFA

6. Email, Phishing, and Social Engineering

Most real incidents start with a convincing message. Treat unexpected requests for credentials, payments, gift cards, or urgent secrecy as suspicious, even when they appear to come from a leader. Verify out of band through a known channel before acting. Multi-factor authentication blocks most credential theft, but a prompt you did not initiate is itself a warning sign · deny it and report it.

- Never approve an MFA prompt you did not start; report unsolicited prompts.
- Hover before you click; check the real sender address, not the display name.
- Finance verifies any payment or banking-detail change by a second channel.

7. Vendors and Third-Party Access

Vendors that touch company or customer data go through a security review before access is granted, sign a data-protection agreement, and receive the minimum access needed for the shortest necessary time. Their access is logged and reviewed on the same schedule as employee production access, and it is revoked promptly when the engagement ends.